

POLICY: DATA PRIVACY & SECURITY

Document ID	SEC-POL-02
Version	2.0
Effective Date	10/2/2026
Department	Compliance & Information Security

1. Scope

Applies to all agents and team leads handling customer data. Violations carry disciplinary consequences up to termination. Complies with GDPR, CCPA, Egypt PDPL Law No. 151/2020, and PCI-DSS.

2. Rules

2.1 Recording & Privacy Disclosure

SEC-RULE-001	Agent must state the recording notification verbatim at call start if not played by IVR: 'This call may be recorded for quality assurance and training purposes.'	CRITICAL
SEC-RULE-002	When requesting sensitive customer data (profile update, new contract), agent must state: 'Your data is used solely for service provisioning and support quality, in accordance with our Privacy Policy.'	MAJOR

2.2 Payment Data (PCI-DSS)

SEC-RULE-003	Agent must never read back a full credit card or bank account number to a customer under any circumstances. Only the last 4 digits may be referenced.	CRITICAL
SEC-RULE-004	Agent must never ask for, record, or repeat a card CVV/CVC code.	CRITICAL

2.3 Data Handling in Notes

SEC-RULE-005	Case notes must mask all sensitive identifiers. Correct: 'Customer verified via card ending in 1234.' Writing full card or account numbers in notes is a CRITICAL violation.	CRITICAL
--------------	--	----------

2.4 Verification Before Access

SEC-RULE-006	Agent must never confirm whether an account exists to an unverified caller. Doing so is a data exposure violation.	CRITICAL
SEC-RULE-007	Credential resets (PIN, security question) may only be performed after successful 3-of-5 identity verification. If verification cannot be completed	CRITICAL

	over the phone, customer must visit a NexaLink store in person with a government-issued photo ID.	
--	---	--

2.5 Suspected Unauthorized Access

SEC-RULE-008	If unauthorized account access is suspected: freeze all account changes, flag account as 'Security Review', escalate to Tier 2 immediately, advise customer to change associated passwords. Data Compliance team follows up within 72 hours.	CRITICAL
---------------------	--	-----------------

2.6 Data Retention

Data Type	Retention Period	Action After Period
Audio call recordings	90 days	Permanently deleted
Call transcripts	1 year	Anonymized and archived
Analytics / metadata	2 years	Aggregated and anonymized

SEC-RULE-009	Customer data deletion requests must be flagged as 'Data Deletion Request' and routed to the Data Compliance Officer. All non-essential PII must be purged within 30 days of confirmed request.	MAJOR
---------------------	---	--------------